

TASK 3: SECURE CODING REVIEW

Title: Secure Coding Review of a PHP Web Application

Selected Application

Programming Language: PHP

Application: Login and Registration System

Review Methods

Security analysis was conducted using:

- * SonarQube
- * PHPStan
- * Manual code inspection

Identified Vulnerabilities

SQL Injection

Vulnerable code:

php

```
$query="SELECT * FROM users WHERE username='$username'";
```

Risk:

- * Database compromise
- * Unauthorized access

Secure code:

php

```
$stmt=$conn->prepare("SELECT * FROM users WHERE username=?");
```

Cross-Site Scripting (XSS)

Vulnerable:

php

```
echo $_GET['name'];
```

Secure:

php

```
echo htmlspecialchars($_GET['name']);
```

Weak Password Storage

Vulnerable:

php

```
$password=$_POST['password'];
```

Secure:

php

```
password_hash($password,PASSWORD_DEFAULT);
```

Poor Session Management

Secure implementation:

php

```
session_regenerate_id(true);
```

Secure Coding Best Practices

- * Validate all inputs
- * Use prepared statements
- * Hash passwords
- * Use HTTPS
- * Apply least privilege
- * Update libraries regularly
- * Avoid exposing error details

FINDINGS SUMMARY

Vulnerability	Risk Level	Recommendation
SQL Injection	High	Prepared statements
XSS	High	Output encoding
Weak passwords	High	Password hashing
Session issues	Medium	Regenerate IDs
Input validation	Medium	Sanitize inputs

CONCLUSION

The review identified several vulnerabilities that could lead to security breaches. Following secure coding practices significantly reduces attack risks and strengthens application security.